

AZURE CAPSTONE PROJECT

TaskFlow: Secure Task and Project Manager

Capstone Submission Document

Item	Details
Alnatum Company Employee	Kreethi G, Cloud & DevOps Engineer Trainee
Project	TaskFlow (Task and Project Manager) on Microsoft Azure
Git repository	https://github.com/Keerthizz/azure-capstone
Live demo URL	https://capstone-12662.centralindia.cloudapp.azure.com (see Section 5 for status)
Submission date	30 September 2026

1. Project Overview

TaskFlow is a web application where a signed-in user can create, edit and delete Projects, add Tasks under a project and mark them done, and comment on tasks. The application domain is Task and Project Manager, chosen from the options in the brief.

The focus of the project is the architecture around the app: identity, network isolation, private database access, automated deployment and monitoring.

Layer	Implementation
Frontend	HTML, CSS, JavaScript single page app hosted as an Azure Storage static website; login with MSAL.js
Identity	Microsoft Entra ID with two App Registrations: capstone-frontend (SPA) and capstone-api (exposes the access scope)
Entry point	Azure Application Gateway with a public IP and HTTPS listener; path routing: / to Storage, /api/* to App Service
Backend	Node.js and Express on Azure App Service, VNet integrated, SystemAssigned Managed Identity, validates the Entra JWT on every call
Database	Azure Cosmos DB (NoSQL API), public network access disabled, reached through a Private Endpoint and Private DNS zone
Network	VNet 10.0.0.0/16 with AppSubnet, DataSubnet and AppGwSubnet
IaC	Bicep template in infra/main.bicep
CI/CD	GitHub Actions: build.yml (CI) and deploy.yml (CD)
Monitoring	Application Insights, Log Analytics workspace, two metric alerts

2. Architecture Diagram

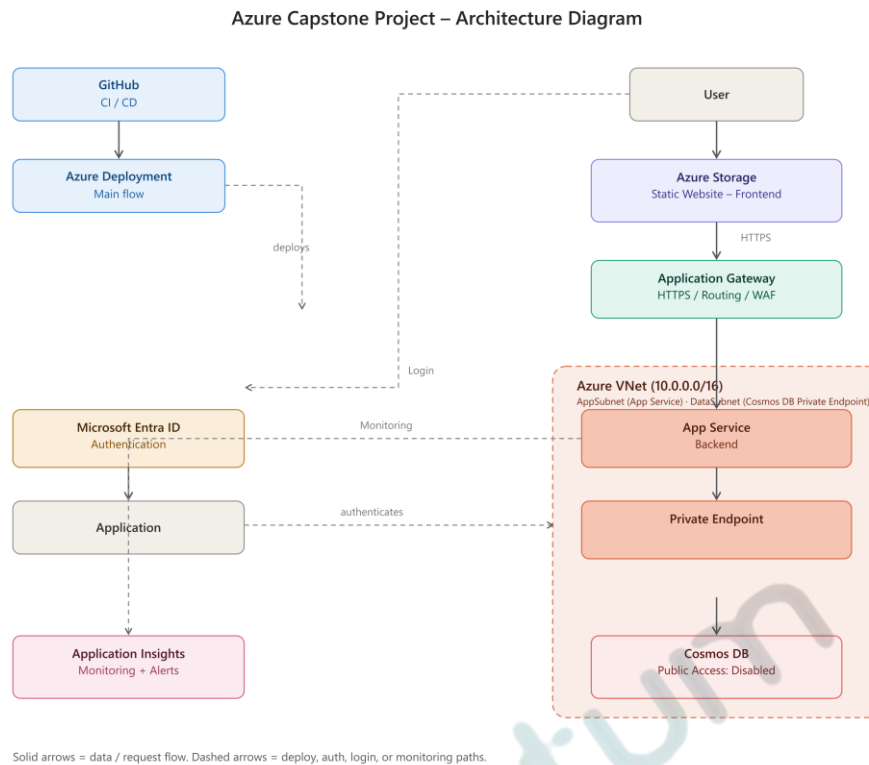


Figure 1: Deployed architecture of TaskFlow

Traffic flow

- The user opens the Application Gateway public URL. The path / is served from the Storage static website.
- Login redirects to Microsoft Entra ID, which returns a JWT access token to the browser.
- Each API call goes to /api/* with the token in the Authorization header. The Gateway routes it to App Service.
- App Service validates the token, then reaches Cosmos DB using its Managed Identity over the VNet through the Private Endpoint.
- Application Insights records request telemetry from the backend.

3. Git Repository

Repository: <https://github.com/Keerthizz/azure-capstone>

Path	Contents
frontend/	index.html: UI, MSAL.js login, API calls with bearer token
backend/	index.js and package.json: Express API for boards, tasks and comments
infra/	main.bicep: VNet, Cosmos DB, App Service, RBAC role assignment, Storage
.github/workflows/	build.yml (CI) and deploy.yml (CD)
README.md	Architecture, decisions, deployment and security notes

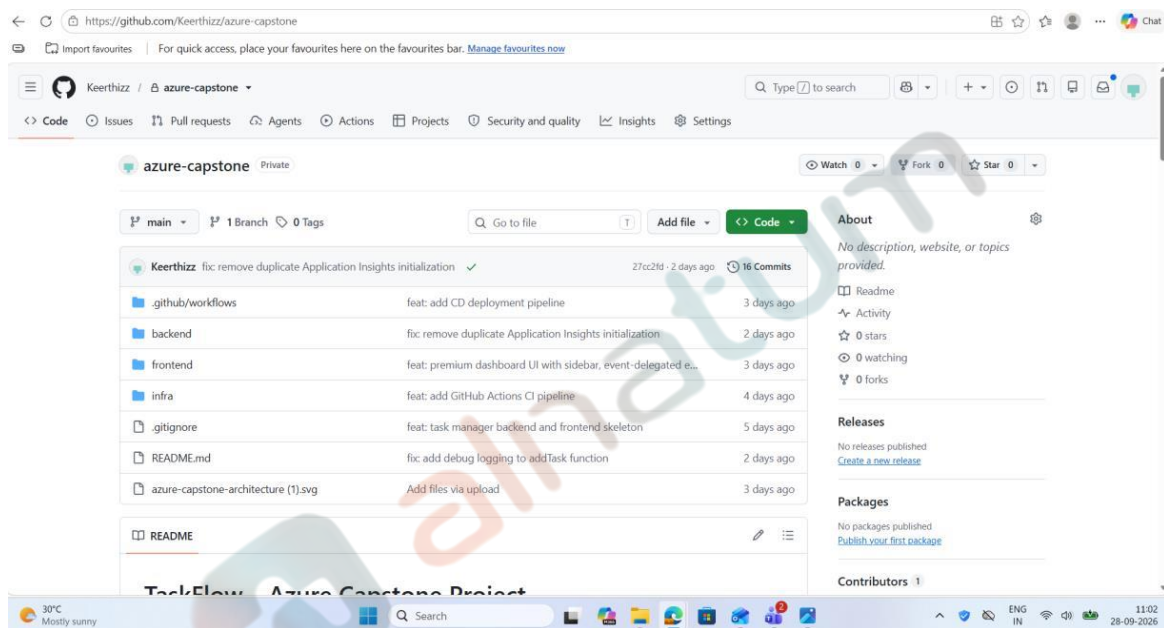


Figure 2: Repository structure and iterative commit history

4. Pipeline Evidence

The pipelines are implemented with GitHub Actions. The brief allows GitHub as the source control platform. The YAML definitions are in the repository under .github/workflows/.

4.1 Build pipeline (CI): build.yml

Runs on every push to main: installs backend dependencies and syntax checks index.js, checks the frontend file, and compiles the Bicep template.

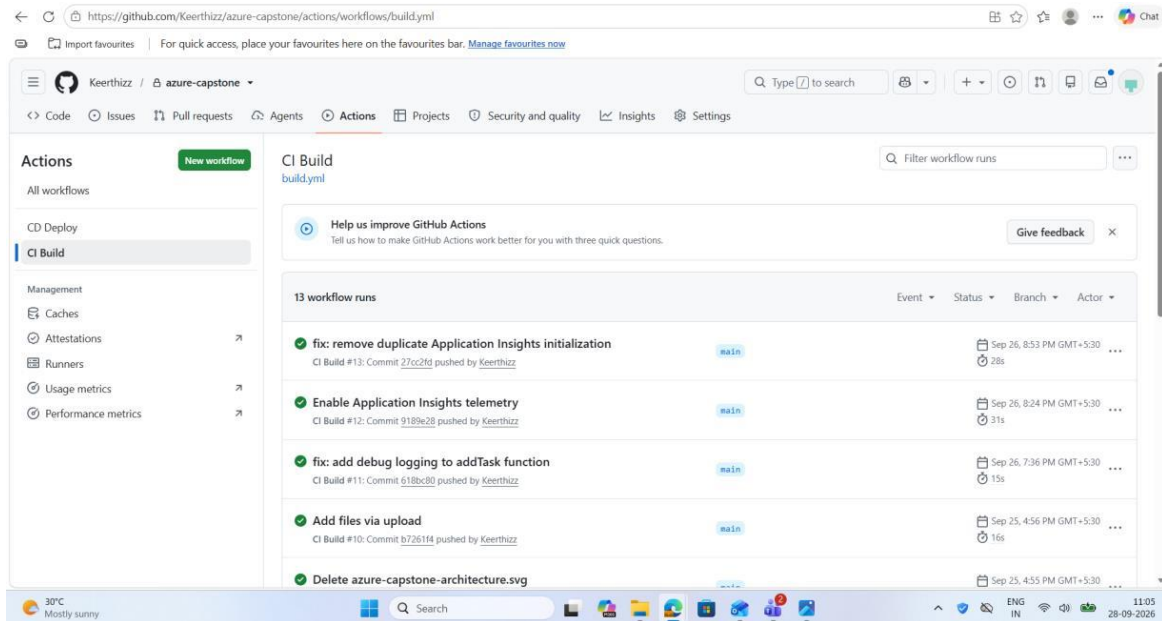


Figure 3: Successful CI Build runs in GitHub Actions

4.2 Release pipeline (CD): deploy.yml

Logs in to Azure with a service principal stored as a GitHub secret, deploys the backend zip to App Service and uploads the frontend to the Storage static website.

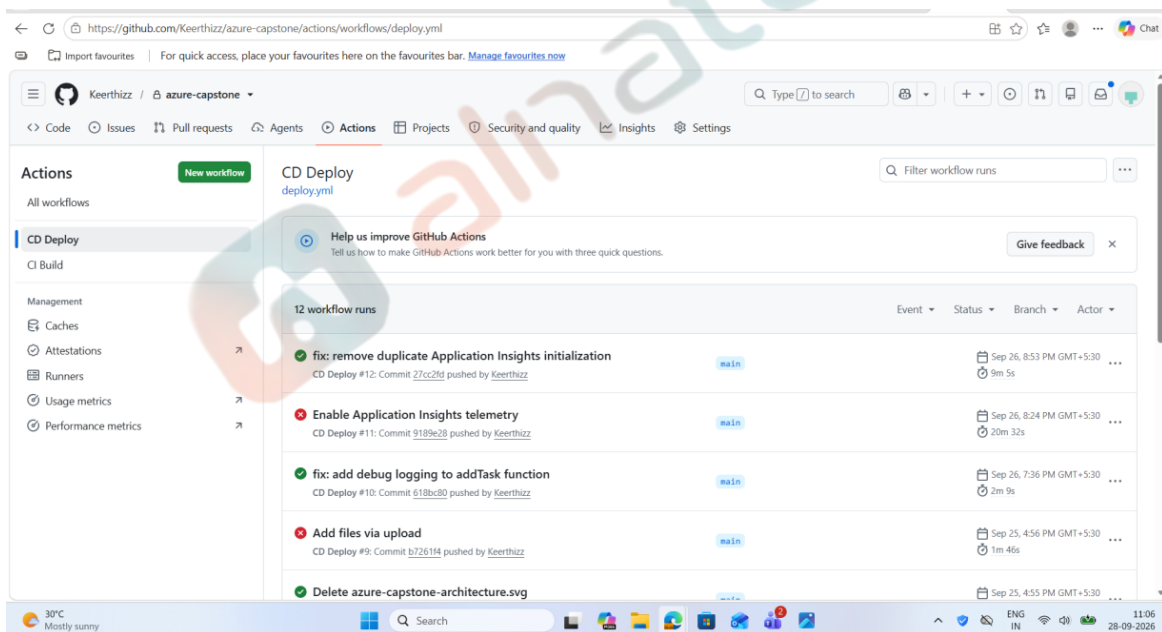


Figure 4: CD Deploy runs in GitHub Actions

5. Live Demo

URL: <https://capstone-12662.centralindia.cloudapp.azure.com>

The Gateway uses a self-signed TLS certificate, so the browser shows a Not secure warning. Click Advanced, then Proceed to continue.

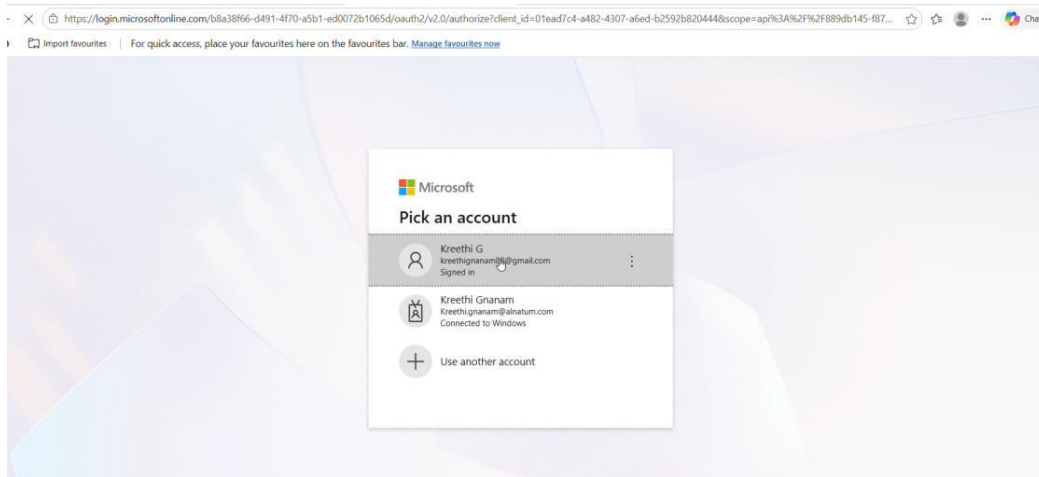


Figure 5: Login with Microsoft Entra ID

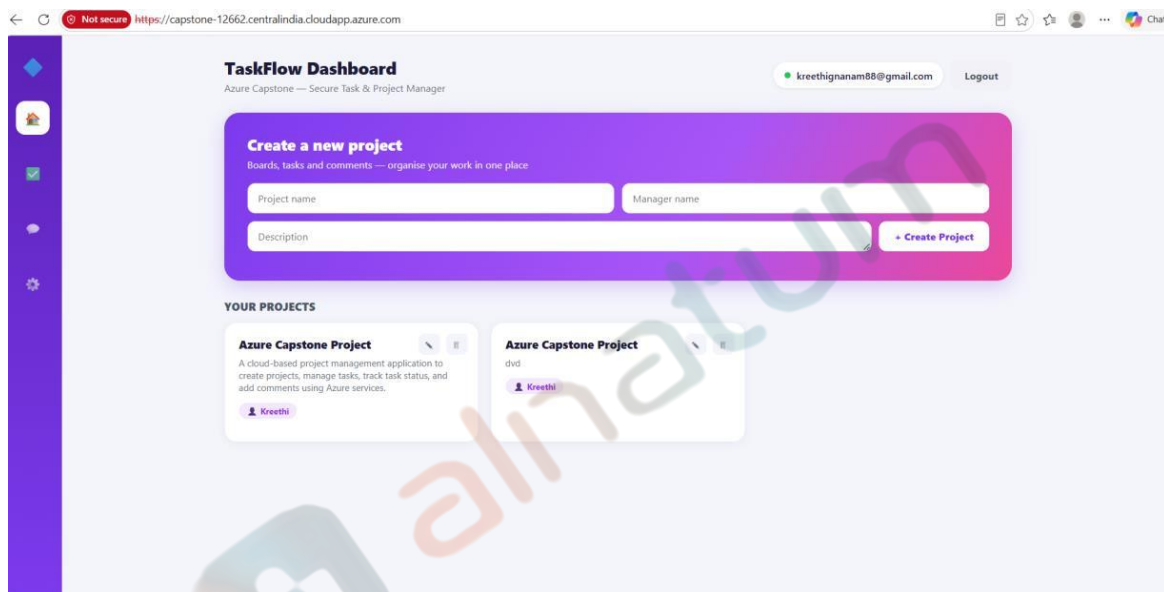


Figure 6: TaskFlow dashboard with the project list loaded from Cosmos DB

Screen Recordings

User Login Demo: [Watch Recording](#)

Edit and Delete Demo: [Watch Recording](#)

User Logout Demo: [Watch Recording](#)

6. Security Evidence

Control	Status	Evidence
Cosmos DB public access disabled	Done	Figure 7
Cosmos DB private endpoint and private DNS	Done	Figure 8
Managed Identity on App Service	Done	Figure 9
No database key in backend code	Done in code	DefaultAzureCredential used when no connection string is set (Figure 10)

Control	Status	Evidence
App Service access restrictions	Not configured	See Section 8

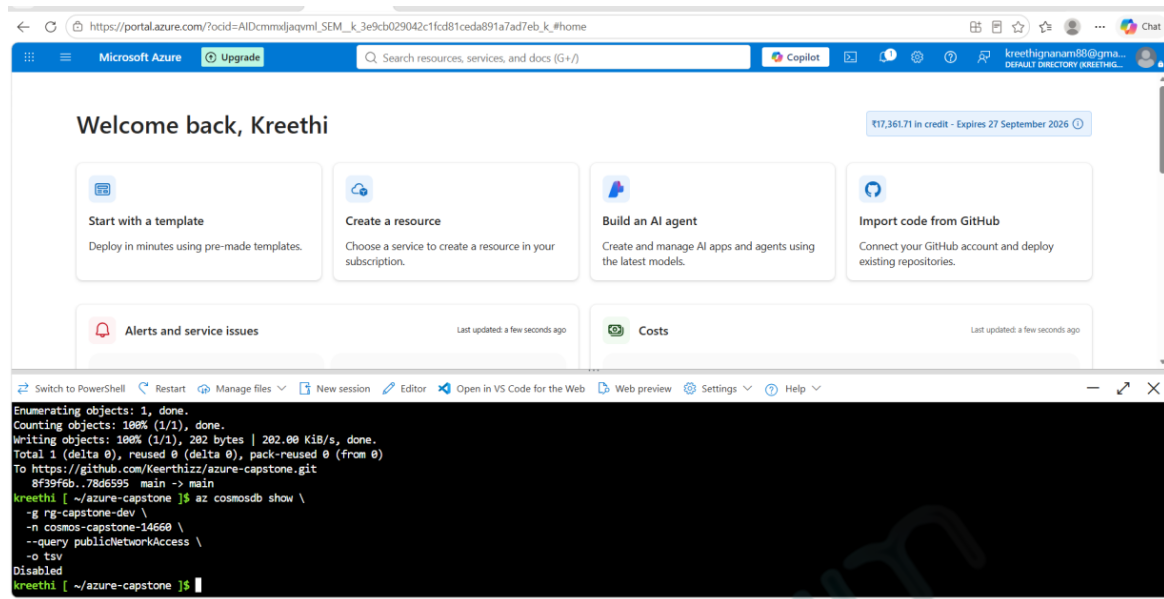


Figure 7: Cosmos DB public network access disabled

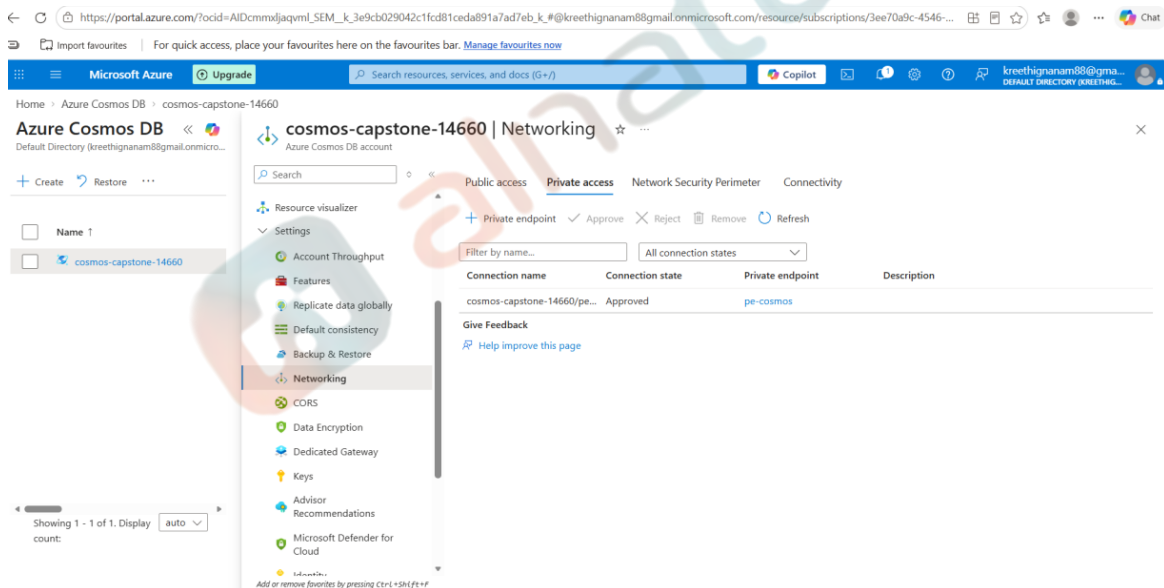


Figure 8: Cosmos DB private endpoint connection (Approved)

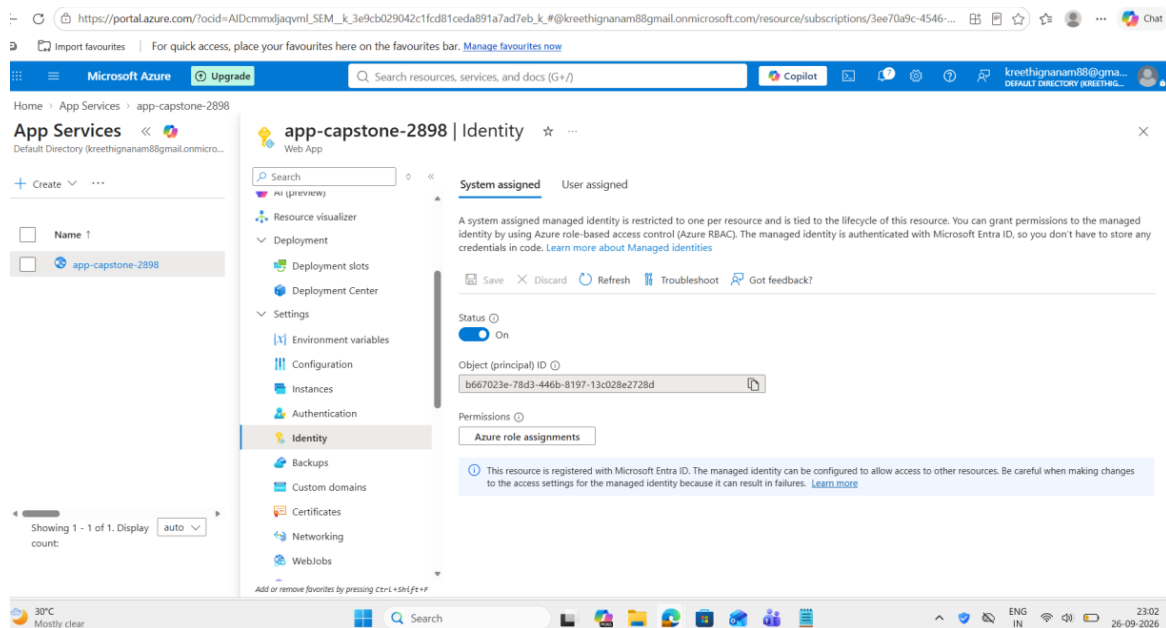


Figure 9: System-assigned Managed Identity enabled on App Service

6.1 How the backend authenticates to Cosmos DB

In Azure the backend builds its Cosmos client with the account endpoint and DefaultAzureCredential, which uses the App Service Managed Identity. That identity was granted the Cosmos DB Built-in Data Contributor role through data-plane RBAC. A connection string is only used for local testing.

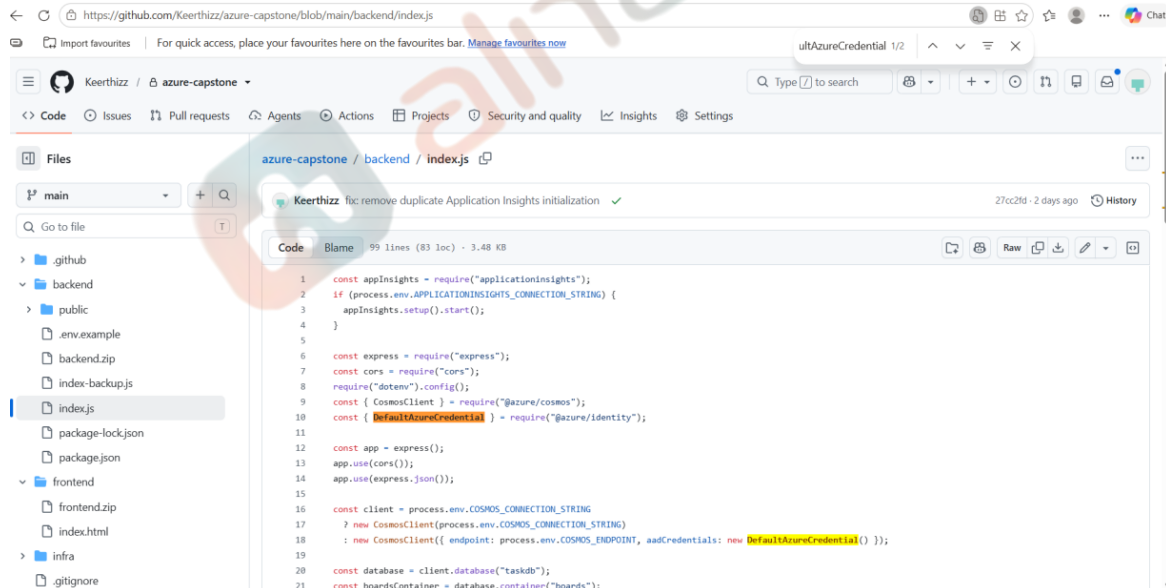


Figure 10: Managed Identity based database access in code

6.2 API protection

Calling /api/boards without a token returns HTTP 401 Unauthorized, because the backend validates the Entra ID token itself.

```
Access-Control-Allow-Origin: *
Content-Type: application/json; charset=utf-8
Content-Length: 259
ETag: W/"103-gdUtbLpMwckKkZzC1NqmdmZgc"
Date: Wed, 23 Sep 2026 09:04:40 GMT
Connection: keep-alive
Keep-Alive: timeout=5

[{"id": "1", "ownerId": "user1", "name": "My First Board", "rid": "ImN-AIOxZxQBAAAAAAAAAA=", "self": "dbs/ImN-AA==/colls/ImN-AIOxZxQ=/docs/ImN-AIOxZxQBAAAAAAAAAA=/", "_etag": "\"270006c5-0000-200-0-0000-6ab35e7acur1 -i http://localhost:3000/api/boards/:1790140826\"}]kreethi [ ~ ]$ curl -i http://localhost:3000/api/boards
HTTP/1.1 200 OK
X-Powered-By: Express
Access-Control-Allow-Origin: *
Content-Type: application/json; charset=utf-8
Content-Length: 259
ETag: W/"103-gdUtbLpMwckKkZzC1NqmdmZgc"
Date: Wed, 23 Sep 2026 09:05:21 GMT
Connection: keep-alive
Keep-Alive: timeout=5

[{"id": "1", "ownerId": "user1", "name": "My First Board", "rid": "ImN-AIOxZxQBAAAAAAAAAA=", "self": "dbs/ImN-AA==/colls/ImN-AIOxZxQ=/docs/ImN-AIOxZxQBAAAAAAAAAA=/", "_etag": "\"270006c5-0000-200-0-0000-6ab35e7acur1 -i http://localhost:3000/api/boards/:1790140826\"}]kreethi [ ~ ]$ curl -i http://localhost:3000/api/boards
HTTP/1.1 401 Unauthorized
X-Powered-By: Express
Access-Control-Allow-Origin: *
Content-Type: application/json; charset=utf-8
Content-Length: 32
ETag: W/"20-ig65TudeTBxir7oplnmTQ2+3xI"
Date: Wed, 23 Sep 2026 09:08:06 GMT
Connection: keep-alive
Keep-Alive: timeout=5

{"error": "Missing Bearer token"}kreethi [ ~ ]$
```

Figure 11: Unauthenticated request rejected

7. Monitoring

Application Insights is connected to the backend through a connection string, with a Log Analytics workspace behind it. Two metric alerts are configured:

- alert-http5xx: backend HTTP 5xx count greater than 5 over 5 minutes.
- alert-cosmos-ru: Cosmos DB Normalized RU Consumption above 80 percent.

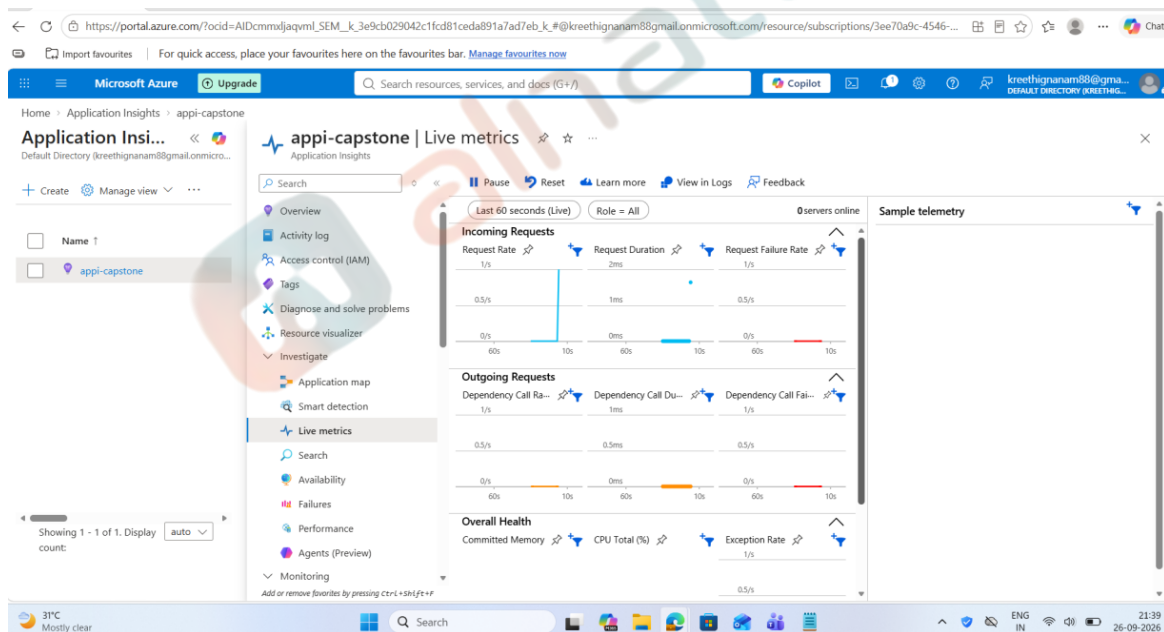


Figure 12: Application Insights live metrics showing requests flowing through the system

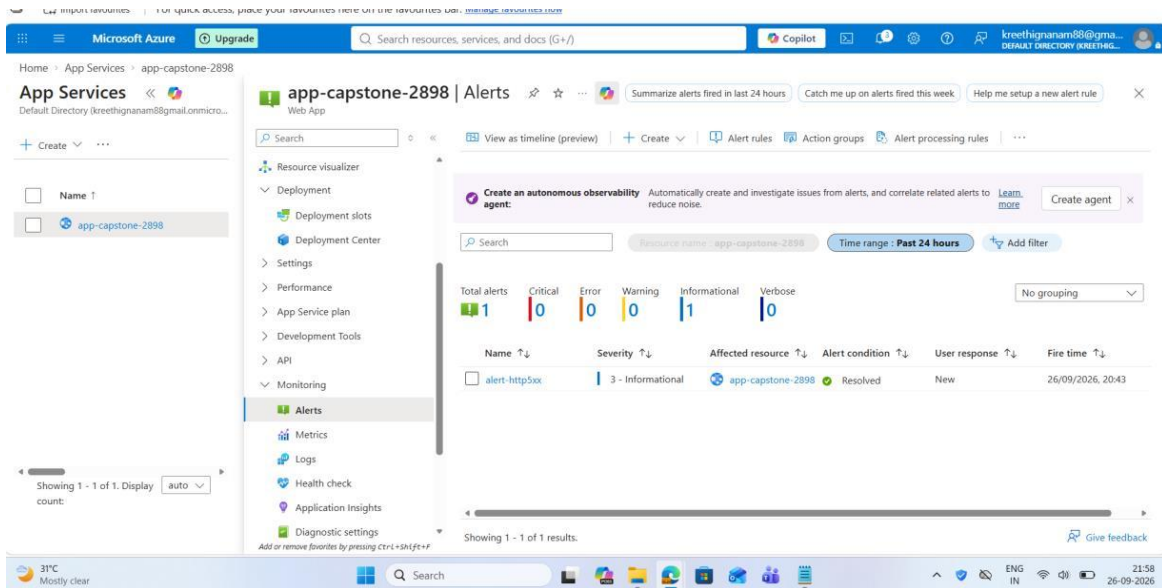


Figure 13: Metric alerts on the App Service

8. Known Limitations and Next Steps

These are stated openly so the assessor sees what was and was not completed.

Item	Status and plan
App Service access restrictions	Not configured. The App Service default hostname is still reachable directly. Next step: restrict inbound to the AppGwSubnet and add NSGs on the subnets.
Web Application Firewall	The Gateway SKU was observed as Standard_v2 and no WAF policy was configured, so WAF protection is not enabled. Next step: move to WAF_v2 with a policy.
TLS certificate	Self-signed certificate for the demo. Production would use a CA-issued certificate.
Pipeline stages	One deployment environment without a Prod approval gate. Next step: Dev and Prod stages with manual approval.
Pipeline location	Workflows are in .github/workflows/ because they run on GitHub Actions, not in /.pipelines.
Entra test account	No separate assessor test user was created before credits ended. Login works with the tenant account used during development.
Bicep coverage	main.bicep covers VNet, Cosmos DB, App Service, RBAC and Storage. The Application Gateway, private endpoint and monitoring were created with the Azure CLI.